

Como Consultor Senior en Ciberseguridad, he realizado un análisis del servidor Linux proporcionado, centrándome en la gestión de usuarios y la exposición de servicios de red. A continuación, presento el informe detallado con mis hallazgos y recomendaciones.

Informe de Auditoría de Ciberseguridad - Servidor Linux

Fecha de Auditoría: 26 de Octubre de 2023 **Servidor Auditado:** Ubuntu Server (IP Hash: 1f30322f033db7321c6e545961f92d4d76a9fec4fc31cd440a70078b12f934fe) **Origen de Datos:** Script Python (conforme a CIS Benchmarks)

1. Resumen Ejecutivo

Este informe detalla los hallazgos de seguridad relacionados con la configuración de usuarios y la exposición de servicios de red en el servidor Ubuntu auditado. Se han detectado dos usuarios con acceso interactivo y dos puertos TCP abiertos (SSH y DNS).

La presencia de múltiples cuentas interactivas combinada con el servicio SSH expuesto representa el riesgo más significativo, ya que aumenta la superficie de ataque para intentos de fuerza bruta o compromiso de credenciales. El servicio DNS (puerto 53/tcp) también requiere validación de su necesidad y endurecimiento si está expuesto públicamente.

Score de Seguridad (1-10, siendo 10 el más seguro): 6/10 El servidor presenta una configuración de seguridad **Moderada**. Si bien no se han detectado vulnerabilidades críticas inmediatas a partir de los datos proporcionados (como root login habilitado o servicios exóticos), la configuración actual de SSH y la gestión de cuentas interactivas ofrecen oportunidades de mejora significativas para reducir la superficie de ataque y mitigar riesgos potenciales.

Acciones Inmediatas Recomendadas: 1. **Endurecimiento de SSH:** Restricción de acceso, uso de autenticación basada en claves, deshabilitación de root login y autenticación por contraseña. 2. **Revisión de Cuentas:** Asegurar que las cuentas interactivas tengan contraseñas robustas y, si es posible, implementar autenticación multifactor (MFA).

2. Hallazgos Prioritarios

Los hallazgos se clasifican por su potencial impacto y la necesidad de atención.

H1: Acceso SSH con Múltiples Cuentas Interactivas (Puerto 22/TCP Abierto)

- Descripción:** El servicio SSH (Puerto 22 TCP) está abierto, permitiendo acceso remoto al servidor. Se han identificado dos usuarios con shell interactivo (/bin/bash) que pueden iniciar sesión, UIDs 1000 y 1001. Esta combinación aumenta significativamente la superficie de ataque para

intentos de compromiso de credenciales (fuerza bruta, relleno de credenciales) en comparación con un sistema con un único punto de entrada o solo autenticación basada en claves.

- **Riesgo:** Alto
- **Correlación:** La exposición de SSH (puerto 22) se correlaciona directamente con la existencia de usuarios interactivos. Cada usuario con shell interactivo es un vector potencial de ataque si sus credenciales son débiles o comprometidas.

H2: Servicio DNS Abierto (Puerto 53/TCP)

- **Descripción:** El puerto 53 TCP, típicamente utilizado por el servicio DNS, está abierto. No se dispone de información adicional sobre el propósito de este servicio (servidor autoritativo, recursivo, solo caché local) ni su alcance (interno/externo). Un servicio DNS mal configurado o expuesto innecesariamente puede ser objeto de ataques como la suplantación de DNS, ataques de amplificación, fuga de información (transferencias de zona no autorizadas) o servir como punto de pivote para ataques internos.
- **Riesgo:** Medio
- **Correlación:** La apertura de este puerto expone una funcionalidad del sistema que, si no es estrictamente necesaria o está correctamente configurada y protegida, podría ser explotada.

H3: Existencia de Múltiples Cuentas con Shell Interactivo

- **Descripción:** Se han identificado dos cuentas de usuario (UID 1000 y UID 1001) configuradas con una shell interactiva (/bin/bash) y la capacidad de iniciar sesión. Aunque la existencia de múltiples usuarios no es intrínsecamente una vulnerabilidad, cada cuenta representa un punto de entrada potencial y aumenta la complejidad de la gestión de identidades y accesos.
- **Riesgo:** Medio
- **Correlación:** Directamente relacionado con H1. La gestión de estas cuentas es crucial para la seguridad general del sistema. La presencia de una cuenta no login (UID 65534) es una buena práctica para usuarios del sistema que no requieren acceso interactivo.

3. Tabla de Riesgos

Riesgo	Severidad	Probabilidad	Impacto	Descripción	Referencia CIS
--------	-----------	--------------	---------	-------------	----------------

Compromiso de Credenciales SSH	Alta	Media	Alta	Un atacante podría obtener acceso interactivo al servidor a través de SSH si las credenciales de los usuarios UID 1000 o UID 1001 son débiles, se adivinan o se fuerzan.	5.3 Ensure SSH Is Configured
Abuso/Explotación de Servicio DNS	Media	Media	Media	Un servicio DNS expuesto y no endurecido puede ser objetivo de ataques de amplificación, envenenamiento de caché o transferencias de zona no autorizadas.	3.5 Ensure DNS Server Is Configured Securely (si aplica)
Elevación de Privilegios por Cuentas No Administradas	Media	Baja	Media	Si una de las cuentas interactivas es comprometida, un atacante podría intentar escalar privilegios si la cuenta tiene permisos excesivos o existen vulnerabilidades locales.	5.1 Ensure Sudo Is Configured, 5.2 Ensure All User Accounts Have Strong Passwords

4. Recomendaciones Técnicas

Las siguientes recomendaciones están diseñadas para mitigar los riesgos identificados y mejorar la postura de seguridad del servidor.

4.1. Endurecimiento del Servicio SSH (Puerto 22/TCP)

Es crítico asegurar la configuración del demonio SSH (sshd).

Deshabilitar la autenticación por contraseña y utilizar solo claves SSH:

- Generar un par de claves SSH para cada usuario que necesite acceso.
- Subir la clave pública al archivo `~/.ssh/authorized_keys` del usuario.
- Editar el archivo de configuración de SSH: `bash sudo nano /etc/ssh/sshd_config`
- Asegurarse de que las siguientes líneas estén configuradas: `PasswordAuthentication no` `PubkeyAuthentication yes` `ChallengeResponseAuthentication no`
- Reiniciar el servicio SSH: `bash sudo systemctl restart sshd`

Deshabilitar el inicio de sesión de root:

- Editar `sshd_config` y asegurarse de que: `PermitRootLogin no`
- Reiniciar el servicio SSH.

Restringir los usuarios que pueden iniciar sesión por SSH:

- Añadir una línea para especificar qué usuarios tienen permitido el acceso SSH. Esto es crucial cuando hay múltiples usuarios: `bash AllowUsers usuario1 usuario2` (Reemplace *usuario1* y *usuario2* con los nombres de usuario correspondientes a los UIDs 1000 y 1001, una vez identificados.)
- Reiniciar el servicio SSH.

Cambiar el puerto por defecto de SSH (Medida de Obscuridad):

- Aunque no es una medida de seguridad robusta, reduce el ruido de los escaneos automatizados.
- Editar `sshd_config` y cambiar la línea `Port 22` a un puerto no estándar (ej. `Port 2322`).
- Asegurarse de que el firewall permita el nuevo puerto.

- Reiniciar el servicio SSH.

4.2. Gestión de Cuentas de Usuario

Auditoría de Cuentas Interactivas:

- Confirmar la necesidad de las cuentas con UID 1000 y 1001. Si alguna no es necesaria, deshabilitarla o eliminarla.
- Para ver el estado de la contraseña de un usuario: `bash sudo chage -l <nombre_de_usuario>`
- Para deshabilitar una cuenta (manteniendo sus archivos): `bash sudo usermod -L <nombre_de_usuario> # Bloquea la contraseña`
`sudo usermod -s /usr/sbin/nologin <nombre_de_usuario> # Cambia el shell a nologin`

Implementar Autenticación Multifactor (MFA):

- Considerar la implementación de MFA para todas las cuentas interactivas, especialmente si el servidor es accesible desde internet. Herramientas como Google Authenticator (PAM module) pueden ser integradas con SSH.

Políticas de Contraseñas Fuertes:

- Asegurarse de que las contraseñas para las cuentas interactivas sean robustas y se cambien periódicamente. Utilizar herramientas como `pam_cracklib` o `pam_pwquality` para forzar políticas de complejidad y longitud.
- Instalar `libpam-pwquality`: `bash sudo apt install libpam-pwquality`
- Editar `/etc/pam.d/common-password` para configurar las políticas.

4.3. Endurecimiento del Servicio DNS (Puerto 53/TCP)

Verificar la Necesidad del Servicio:

- Determinar si el servidor realmente necesita ofrecer servicios DNS. Si no es así, el servicio debe ser deshabilitado.

- Para identificar el proceso que escucha en el puerto 53: `bash sudo lsof -i :53 sudo netstat -tulpn | grep :53`
- Para detener y deshabilitar un servicio (ej. bind9 o dnsmasq): `bash sudo systemctl stop <nombre_del_servicio_dns> sudo systemctl disable <nombre_del_servicio_dns>`

Restringir Acceso con Firewall:

- Si el servicio DNS es necesario, limitar el acceso a solo las IPs o subredes autorizadas.
- **Usando UFW (Uncomplicated Firewall):** `bash sudo ufw enable sudo ufw default deny incoming sudo ufw allow in on eth0 to any port 53 from <IP_o_Subred_Autorizada> proto tcp sudo ufw allow in on eth0 to any port 53 from <IP_o_Subred_Autorizada> proto udp # DNS también usa UDP sudo ufw allow in on eth0 to any port 22 from <IP_o_Subred_Autorizada_SSH> proto tcp # Mantener acceso SSH`
- **Usando iptables (si UFW no está en uso):** `bash sudo iptables -A INPUT -p tcp --dport 53 -s <IP_o_Subred_Autorizada> -j ACCEPT sudo iptables -A INPUT -p udp --dport 53 -s <IP_o_Subred_Autorizada> -j ACCEPT sudo iptables -A INPUT -p tcp --dport 53 -j DROP # Denegar el resto sudo iptables -A INPUT -p udp --dport 53 -j DROP # Denegar el resto # Guardar las reglas (dependiendo de la distribución, puede ser service netfilter-persistent save o iptables-save > /etc/iptables/rules.v4)`

Endurecimiento de la Configuración DNS:

- Si el servidor DNS es autoritativo, deshabilitar las transferencias de zona para IPs no autorizadas.
- Deshabilitar la recursión si no es un servidor DNS recursivo para clientes internos.
- Mantener el software DNS (ej. bind9, dnsmasq) actualizado a la última versión para parchear vulnerabilidades conocidas.

4.4. Recomendaciones Generales

Actualizaciones del Sistema:

- Mantener el sistema operativo y todas las aplicaciones actualizadas para protegerse contra vulnerabilidades conocidas.
- `bash sudo apt update && sudo apt upgrade -y sudo apt dist-upgrade -y sudo reboot # Si se actualizó el kernel`

Auditoría de Logs:

- Implementar una solución de monitoreo y análisis de logs (syslog, auditd, SIEM) para detectar actividades sospechosas, intentos de inicio de sesión fallidos, etc.
- ```
bash sudo apt install auditd sudo systemctl enable auditd sudo systemctl start auditd
```
- Configurar reglas para monitorear eventos críticos.

### Principio de Mínimo Privilegio:

- Asegurar que todos los usuarios y servicios operen con el mínimo conjunto de privilegios necesarios para realizar sus funciones.

---

Este informe proporciona una base sólida para mejorar la postura de seguridad del servidor. Se recomienda implementar estas recomendaciones de manera escalonada, realizando pruebas en un entorno de no producción primero cuando sea posible.